Legal aspects of IT security
Master in cybersecurity

Elise Delhaise

Academic year 2025-2026

UNIVERSITÉ DE NAMUR

NIS Directives

UNIVERSITÉ DE NAMUR

NIS Directives

- Directive (UE) 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union, *J.O.*, 19 July 2016, L 194 ;

- Directive (UE) 2016/1148 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148, *J.O.*, 27 December 2022, L 333.

Summary

I. Subject matter
II. Preliminary concepts
III. Scope
IV. Cybersecurity risk-management measures
V. Reporting obligations
VI. Supervision and enforcement
VII. Penalties
VIII. Transposition

I. Subject matter

NIS II Directive strengthens cybersecurity obligations compared with NIS I Directive

Several changes:

- Broader scope of application
- Reinforcement of cybersecurity risk management measures
- Extension of information and incident notification obligations
- Penalties

I. Subject matter

-> Establishment of measures aimed at achieving a high common level of cybersecurity throughout the Union, in order to improve the functioning of the internal market

Establishment :

- Obligations for Member States to adopt national cybersecurity strategies
- Cybersecurity risk management measures and information obligations
- Rules and obligations for information sharing
- Obligations for Member States in terms of supervision and enforcement

II. Preliminary concepts

- **Network and information system** =

a) "*an electronic communications network as defined in Article 2, point (1), of Directive (EU) 2018/1972;*

b) any device or group of interconnected or related devices, one or more of which, pursuant to a programme, carry out automatic processing of digital data; or

c) digital data stored, processed, retrieved or transmitted by elements covered under points (a) and (b) for the purposes of their operation, use, protection and maintenance" (Directive 2022/2555, art. 6, 1°)

- **Security of network and information systems** = « *the ability of network and information systems to resist, at a given level of confidence, any event that may compromise the availability, authenticity, integrity or confidentiality of stored, transmitted or processed data or of the services offered by, or accessible via, those network and information systems* » (Directive 2022/2555, art. 6, 2°)

III. Scope

- Entity active in a sector (or sub-sector) listed in the annexes to the directive
- An entity of a certain size
- Essential or important entity

III. Scope

- **Entity active in a sector (or sub-sector) listed in the annexes to the directive**

- Sectors of high criticality (Annex I)

- Other critical sectors (Annex II)

III. Scope

- **Entity active in a sector (or sub-sector) listed in the annexes to the directive**

- Sectors of high criticality (Annex I)

Energy (electricity, heating and cooling networks, oil, gas, hydrogen)

Transport (air, rail, water, road)

Banking sector

Financial market infrastructures

Health

Drinking water

Waste water

Digital infrastructure

ICT service management

Public administration

Space

III. Scope

- **Entity active in a sector (or sub-sector) listed in the annexes to the directive**

- Other critical sectors (Annex II)

Postal and shipping services

Waste management

Manufacture, production and distribution of chemical products

Production, processing and distribution of foodstuffs

Manufacturing (of medical devices and in vitro diagnostic medical devices, computer, electronic and optical products, electrical equipment, machinery and equipment n.e.c., motor vehicles, trailers and semi-trailers, other transport equipment)

Digital suppliers

Research

III. Scope

- **Entities of a certain size**

- Large company

Employs at least 250 people or has an annual turnover in excess of €50 million

- Medium-sized company

Employs at least 50 people or whose annual turnover exceeds €10 million BUT employs fewer than 250 people and whose annual turnover does not exceed €50 million.

III. Scope

- **Essential or important entity**

- Essential entity

Large company operating in a sector of high criticality

- Important entity

Medium-sized company active in a sector of high criticality and medium-sized or large company active in another critical sector

! Exceptions*

III. Scope

- **Essential or important entity**

Exceptions

- Essential entities in certain sectors, regardless of size

- Essential or significant entities designated by national authorities

IV. Cybersecurity risk-management measures

« *Member States shall ensure that essential and important entities take <u>appropriate and proportionate</u> technical, operational and organisational measures to manage <u>the risks</u> posed to the security of network and information systems which those entities use for their operations or for the provision of their services, and <u>to prevent or minimise the impact of incidents</u>* on recipients of their services and on other services.* » (Directive 2022/2555, art. 20, §1er)

IV. Cybersecurity risk-management measures

- Level of security adapted to the risk
- Proportionate measures
- Appropriate measures
- Incident management
- List of minimum measures

IV. Cybersecurity risk-management measures

- **Level of security adapted to the risk**

Risk = « *the potential for loss or disruption caused by an incident and is to be expressed as a combination of the magnitude of such loss or disruption and the likelihood of occurrence of the incident* » (Directive 2022/2555, art. 6, 9°)

an « all-hazards » approach (Directive 2022/2555, considérant 79)

- **Proportionate measures**

Assessment of the proportionality of the measures: degree of exposure of the entity to the risks, size of the entity, probability of the occurrence of incidents and their severity

IV. Cybersecurity risk-management measures

- **Appropriate measures**

Parameters to be taken into account: state of the art, cost of implementation, existence of applicable standards, etc.

- **Incident management**

Incident = « *an event compromising the availability, authenticity, integrity or confidentiality of stored, transmitted or processed data or of the services offered by, or accessible via, network and information systems* » (Directive 2022/2555, art. 6, 6°)

IV. Cybersecurity risk-management measures

- **List of minimum measures**

« *(a) policies on risk analysis and information system security;*

(b) incident handling;

(c) business continuity, such as backup management and disaster recovery, and crisis management;

(d) supply chain security, including security-related aspects concerning the relationships between each entity and its direct suppliers or service providers;

(e) security in network and information systems acquisition, development and maintenance, including vulnerability handling and disclosure;

(f) policies and procedures to assess the effectiveness of cybersecurity risk-management measures;

(g) basic cyber hygiene practices and cybersecurity training;

(h) policies and procedures regarding the use of cryptography and, where appropriate, encryption;

(i) human resources security, access control policies and asset management;

(j) the use of multi-factor authentication or continuous authentication solutions, secured voice, video and text communications and secured emergency communication systems within the entity, where appropriate» (Directive 2022/2555, art. 21, §2)

V. Reporting obligations

- Notification of significant incidents*
- Without undue delay
- To your CSIRT* or, where appropriate, to the competent authority

V. Reporting obligations

« An incident shall be considered to be significant if:

(a) it has caused or is capable of causing severe operational disruption of the services or financial loss for the entity concerned;

(b) it has affected or is capable of affecting other natural or legal persons by causing considerable material or non-material damage» (Directive 2022/2555, art. 23, §3)

V. Reporting obligations

CSIRT* = Computer security incident response teams

Tasks (Directive 2022/2555, art. 11, §3) :

a) monitoring and analysing cyber threats, vulnerabilities and incidents at national level and, upon request, providing assistance to essential and important entities concerned regarding real-time or near real-time monitoring of their network and information systems;

b) providing early warnings, alerts, announcements and dissemination of information to essential and important entities concerned as well as to the competent authorities and other relevant stakeholders on cyber threats, vulnerabilities and incidents, if possible in near real-time;

c) responding to incidents and providing assistance to the essential and important entities concerned, where applicable;

d) collecting and analysing forensic data and providing dynamic risk and incident analysis and situational awareness regarding cybersecurity[…]

V. Reporting obligations

[…]

e) providing, upon the request of an essential or important entity, a proactive scanning of the network and information systems of the entity concerned to detect vulnerabilities with a potential significant impact;

f) participating in the CSIRTs network and providing mutual assistance in accordance with their capacities and competencies to other members of the CSIRTs network upon their request;

g) where applicable, acting as a coordinator for the purposes of the coordinated vulnerability disclosure under Article 12(1);

h) contributing to the deployment of secure information-sharing tools pursuant to Article 10(3).

V. Reporting obligations

Reporting process (Directive 2022/2555, art. 23, §4):

- Early warning within 24 hours of becoming aware of the significant incident
- Incident notification within 72 hours of becoming aware of the significant incident : update of information notified during the early warning and initial assessment of the major incident
- Intermediate report on relevant status updates
- Final report not later than one month after the submission of the incident notification
- (Progress report)

V. Reporting obligations

+ communication to the recipients of their services that are potentially affected by a significant* cyber threat* any measures or remedies that those recipients are able to take in response to that threat

- Cyberthreat = « *any potential circumstance, event or action that could damage, disrupt or otherwise adversely impact network and information systems, the users of such systems and other persons*» (Règlement 2019/881, art. 2, 8°)
- Significant cyberthreat = « *a cyber threat which, based on its technical characteristics, can be assumed to have the potential to have a severe impact on the network and information systems of an entity or the users of the entity's services by causing considerable material or non-material damage*» (Directive 2022/2555, art. 6, 11°)

VI. Supervision and enforcement

Supervision by the competent national authorities (designated by the Member States and responsible for cyber security at national level)

Distinction :

- Measures in relation to essential entities
- Measures in relation to important entities

VI. Supervision and enforcement

	Essential entities	Important entities
Competent authorities' supervisory tasks	Directive 2022/2555, art. 32, § 2	Directive 2022/2555, art. 33, § 2
Competent authorities' enforcement powers	Directive 2022/2555, art. 32, § 4	Directive 2022/2555, art. 33, § 4

Differences between essential and significant entities :

- Stricter controls for essential entities
- Stricter penalties for essential entities

VII. Penalties

« *Member States shall lay down rules on penalties applicable to infringements of national measures adopted pursuant to this Directive and shall take all measures necessary to ensure that they are implemented. The penalties provided for shall be effective, proportionate and dissuasive. Member States shall, by 17 January 2025, notify the Commission of those rules and of those measures and shall notify it, without delay of any subsequent amendment affecting them* » (Directive 2022/2555, art. 36)

VIII. Transposition

- Adoption and publication by 17 October 2024
- Application from 18 October 2024

-> Loi du 26 avril 2024 établissant un cadre pour la cybersécurité des réseaux et des systèmes d'information d'intérêt général pour la sécurité publique, *M.B.*, 17 mai 2024, 1e éd., p. 63179.

Any questions ?

Thanks for your attention!

UNIVERSITÉ DE NAMUR